

Plan de Respuesta a Incidentes de Ransomware: TechCo

Analista: Julio Fraga

Versión: 1.0

Fecha: 4 de mayo de 2026

Tabla de Contenidos

1. Introducción
2. Identificación de Activos y Vulnerabilidades
3. Medidas de Protección y Mitigación
4. Protocolos de Detección Temprana
5. Plan de Respuesta y Contención
6. Estrategia de Recuperación y Continuidad
7. Mejora Continua y Post-Incidente

1. Introducción

El presente documento establece la estrategia formal para gestionar y mitigar el impacto de ataques de ransomware en TechCo. El objetivo primordial es salvaguardar la integridad de los datos de los clientes y asegurar la resiliencia operativa frente a amenazas de cifrado malicioso.

2. Identificación de Activos y Vulnerabilidades

Se ha realizado un diagnóstico de los componentes críticos comprometidos durante el incidente para priorizar los esfuerzos de defensa:

- **Activos de Alta Criticidad:** Servidor de archivos operativos, base de datos de clientes (PII) y sistemas de respaldo internos.
- **Vulnerabilidades Detectadas:** Ausencia de segmentación de red (arquitectura plana), falta de inmutabilidad en los backups y carencia de filtros avanzados contra ataques de ingeniería social (*phishing*).
- **Evaluación de Impacto:** La pérdida de acceso a estos activos representa un riesgo existencial para la operatividad y la reputación legal de la firma.

3. Medidas de Protección y Mitigación

Para fortalecer la infraestructura, se implementarán los siguientes controles preventivos:

- **Segmentación de Red:** División de la red en subredes aisladas para impedir el movimiento lateral del ransomware.
- **Gestión de Acceso Robusta:** Implementación de Autenticación de Múltiples Factores (MFA) y el principio de menor privilegio (PoLP) en todas las capas administrativas.
- **Protección de Datos:** Adopción de la regla **3-2-1-1**, asegurando que al menos una copia de seguridad permanezca en un estado inmutable y fuera de línea (*air-gapped*).

4. Protocolos de Detección Temprana

La capacidad de detección se fundamenta en la identificación de anomalías antes de la fase de cifrado masivo:

- **Herramientas EDR/XDR:** Despliegue de soluciones en endpoints para monitorear comportamientos de archivos y procesos sospechosos en tiempo real.
- **Monitoreo de Logs (SIEM):** Centralización de eventos para identificar intentos de exfiltración de datos o escalada de privilegios.
- **Alertas de Umbral:** Configuración de alarmas automáticas ante picos inusuales de lectura/escritura en los servidores de archivos.

5. Plan de Respuesta y Contención

Ante la activación de una alerta de ransomware, se ejecutará el siguiente protocolo de respuesta:

- **Aislamiento Inmediato:** Desconexión de los sistemas infectados de la red corporativa para detener la propagación.
- **Asignación de Roles:**
 - **Coordinador de Incidentes:** Dirige la ejecución técnica.
 - **Analista Forense:** Determina el vector de entrada y la variante del malware.
 - **Enlace de Comunicación:** Gestiona la información hacia la gerencia y entes regulatorios.
- **Comunicación Externa:** Notificación a las autoridades pertinentes y clientes afectados, conforme a los marcos legales vigentes.

6. Estrategia de Recuperación y Continuidad

La restauración de los servicios se llevará a cabo bajo condiciones estrictas de seguridad:

- **Limpieza y Verificación:** Eliminación de persistencias maliciosas antes de iniciar la carga de datos.
- **Restauración Priorizada:** Recuperación de la base de datos de clientes en primera instancia, seguida de los servicios de producción esenciales.
- **Continuidad Operativa:** Ejecución de procesos de contingencia manuales para minimizar la interrupción del servicio al cliente durante el periodo de recuperación técnica.

7. Mejora Continua y Post-Incidente

La resiliencia de TechCo se basa en el aprendizaje derivado de cada evento:

- **Análisis de Lecciones Aprendidas:** Elaboración de un informe detallado que documente las fallas de control y el desempeño del equipo de respuesta.

- **Actualización de Políticas:** Ajuste de los procedimientos de seguridad y entrenamiento del personal basado en los hallazgos del incidente.
- **Auditorías de Validación:** Realización de pruebas de penetración y simulacros de ransomware para verificar la eficacia de las nuevas medidas implementadas.